Protocolos HTTP/HTTPS; Criptografia; Chamada de Procedimento Remoto (RPC).

- Willian Marques Freire

Universidadequetransforma

UTFPR
UNIVERSIDADE TECNOLÓGICA FEDERAL DO PARANÁ

Aulas anteriores…

- Fundamentação da Camada de Aplicação;
- Protocolos de Transporte (TCP e UDP);
- Elementos da Segurança da Informação;
- Arquiteturas de Sistemas Distribuídos;

Antes de iniciarmos os próximos assuntos:

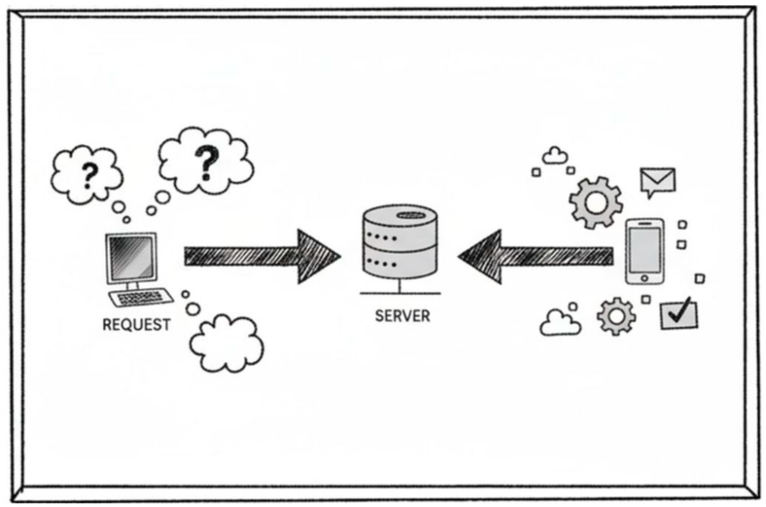
“Qual é a língua que a web fala?”

Protocolo HTTP *(Hypertext Transfer Protocol)*

- **“Idioma” comum para comunicação entre diferentes sistemas;**

- **Protocolo para a troca de informações na internet, permitindo o envio (requisição) e recebimento (resposta) de dados entre um navegador (cliente) e um servidor;**

- **O cliente requisita e um servidor responde;**



Protocolo HTTP

- **Protocolo Stateless;**
  - **Sem estado - Sem memória;**
  - **O servidor não mantém informações sobre requisições anteriores de um mesmo cliente;**
  - **Cada requisição como se fosse a primeira;**

Como sites mantém o estado? Ex: Login, carrinho de compras…

Cookies

- O servidor entrega um ID ao cliente, que o usa para manter a sessão;
  - O navegador armazena;
    - Ex: Crachá;
    - Responsabilidade de se lembrar quem é o cliente;

- *Página 85 do livro Redes de Computadores e a Internet de Kurose e Ross;*

Requisição HTTP

- Uma requisição HTTP contém o método, a URL, cabeçalhos e um corpo opcional;
  - Ex: carta bem organizada;
  - Primeira linha mais importante;
    - Método: ação
    - URL: Endereço
    - Versão do HTTP;

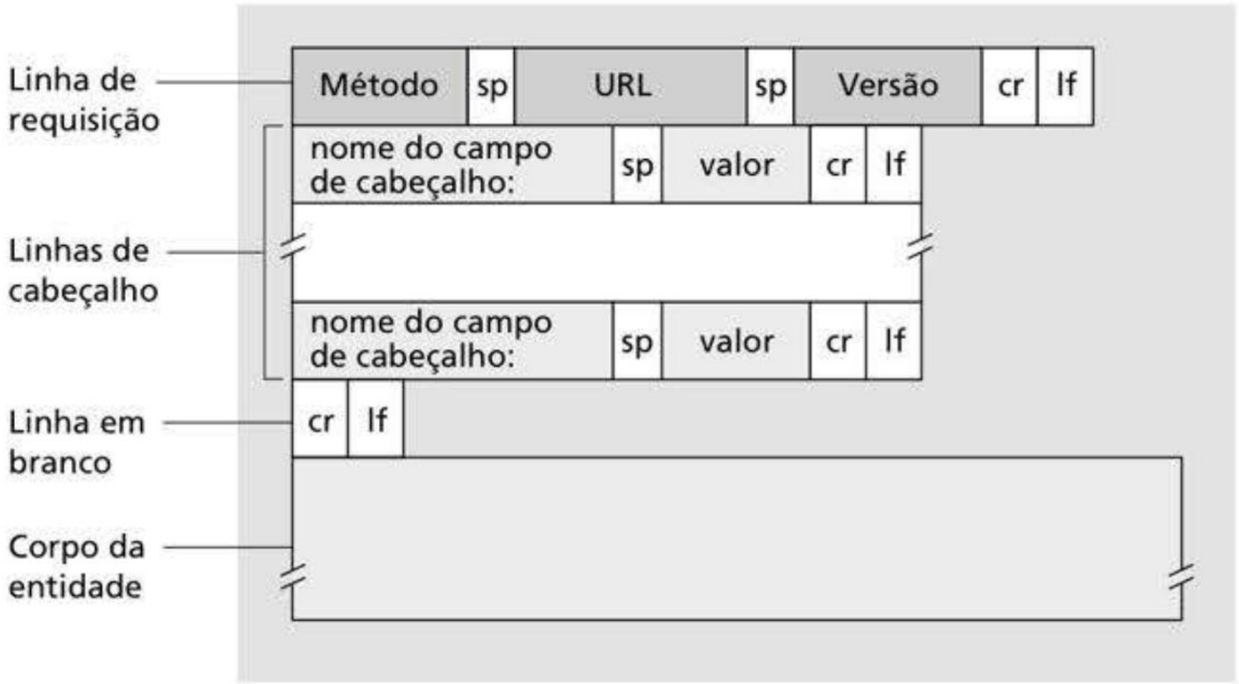


Figura 2.8 Formato geral de uma mensagem de requisição HTTP.

- *Página 82 do livro Redes de Computadores e a internet de Kurose e Ross;*

Métodos HTTP

Método	Função	Características	Exemplo	Idempotente
GET	Buscar/obter dados	Não altera dados Parâmetros na URL	Listar clientes do CRM	✅
POST	Criar novos recursos	Cria novos dados Dados no corpo da requisição	Cadastrar novo lead	❌
PUT	Atualizar completamente	Substitui recurso inteiro Todos os campos necessários	Atualizar perfil completo do cliente	✅
PATCH	Atualizar parcialmente	Modifica campos específicos Mais eficiente para pequenas mudanças	Alterar apenas status do pedido	⚠️
DELETE	Remover dados	Remove recursos Geralmente irreversível	Cancelar agendamento	✅

- **Outros métodos incluem** HEAD, OPTIONS, CONNECT e TRACE

Resposta HTTP

- **Para toda requisição, o servidor retorna uma resposta;**
  - **Estrutura similar com a requisição;**
  - **Cabeçalhos e corpo de resposta;**
  - **Uma resposta HTTP inclui um código de status (ex: 200 OK) e os dados.**

- `200 OK`: requisição bem-sucedida e a informação é entregue com a resposta.
- `301 Moved Permanently`: objeto requisitado foi removido em definitivo; novo URL é especificado no cabeçalho `Location:` da mensagem de resposta. O *software* do cliente recuperará automaticamente o novo URL.
- `400 Bad Request`: código genérico de erro que indica que a requisição não pôde ser entendida pelo servidor.
- `404 Not Found`: o documento requisitado não existe no servidor.
- `505 HTTP Version Not Supported`: a versão do protocolo HTTP requisitada não é suportada pelo servidor.

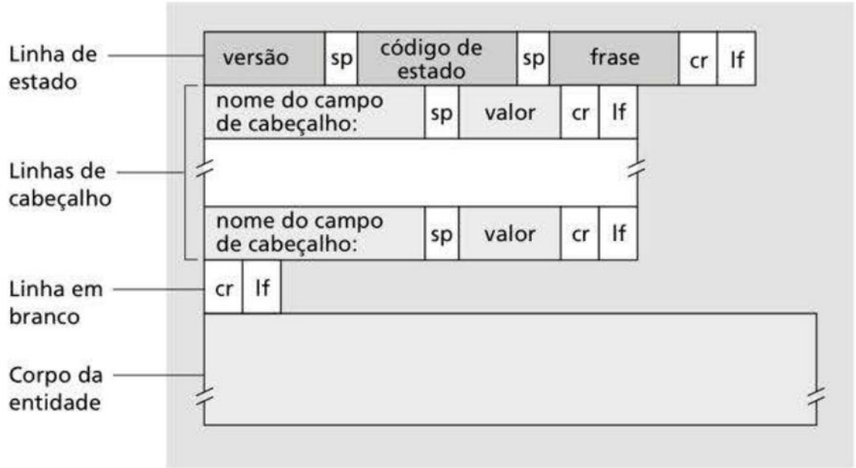


Figura 2.9 Formato geral de uma mensagem de resposta HTTP.

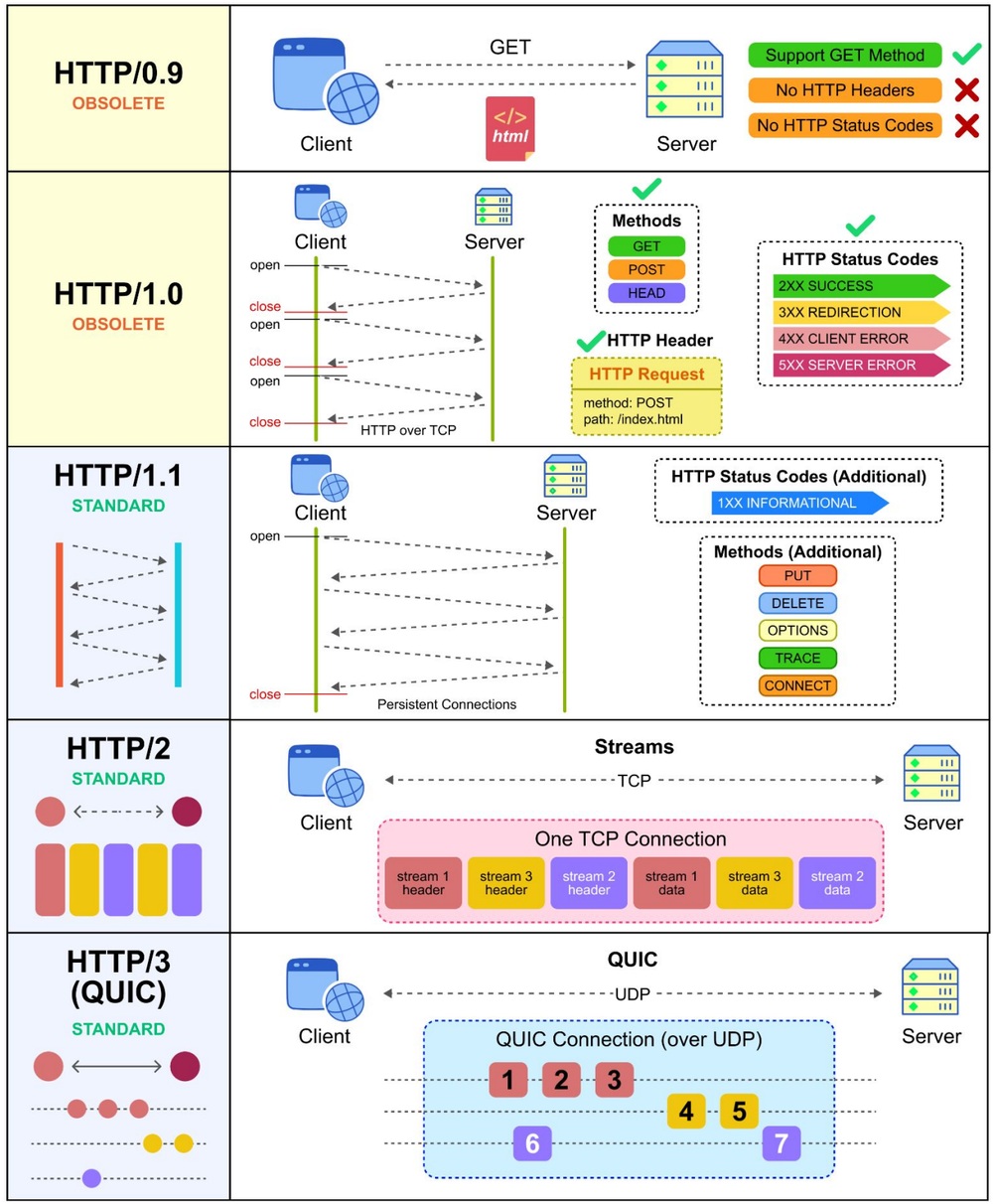
- ***Página 83 do livro Redes de Computadores e a internet de Kurose e Ross;***

Códigos de status HTTP

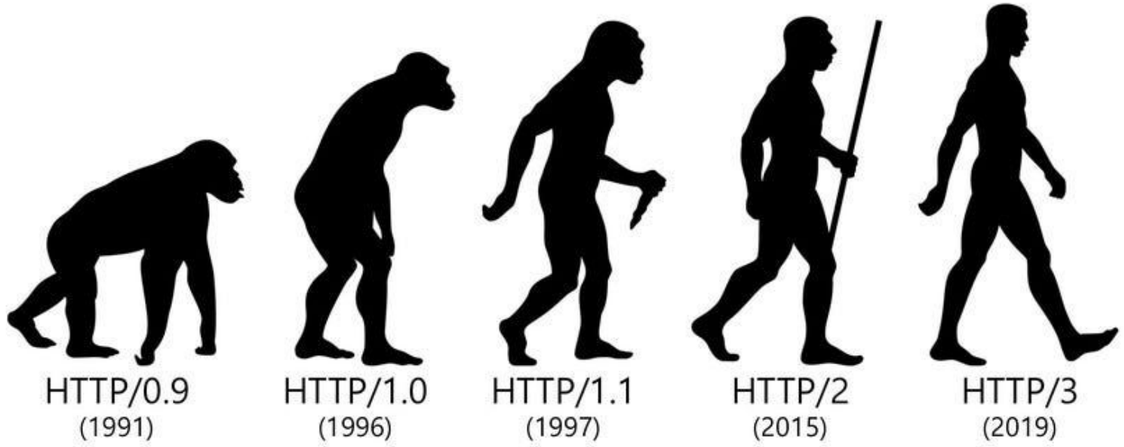
- Não são aleatórios;
- Agrupados por famílias;

Evolution of HTTP

ByteByteGo



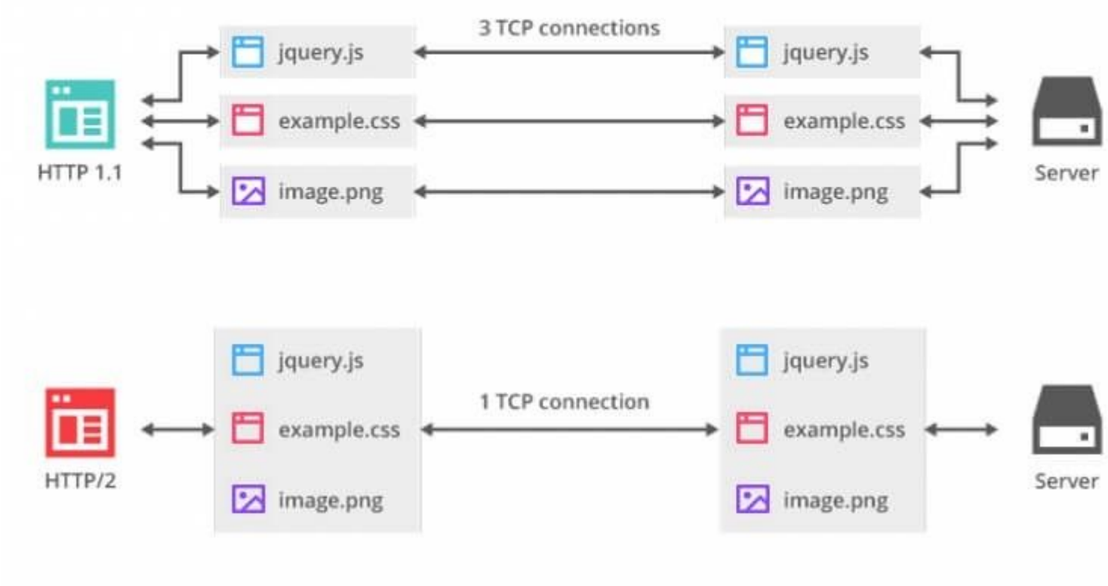
- Evolução do HTTP;
- Conexões persistentes;
- *Head of line blocking* (Ex: cabine de pedágio);



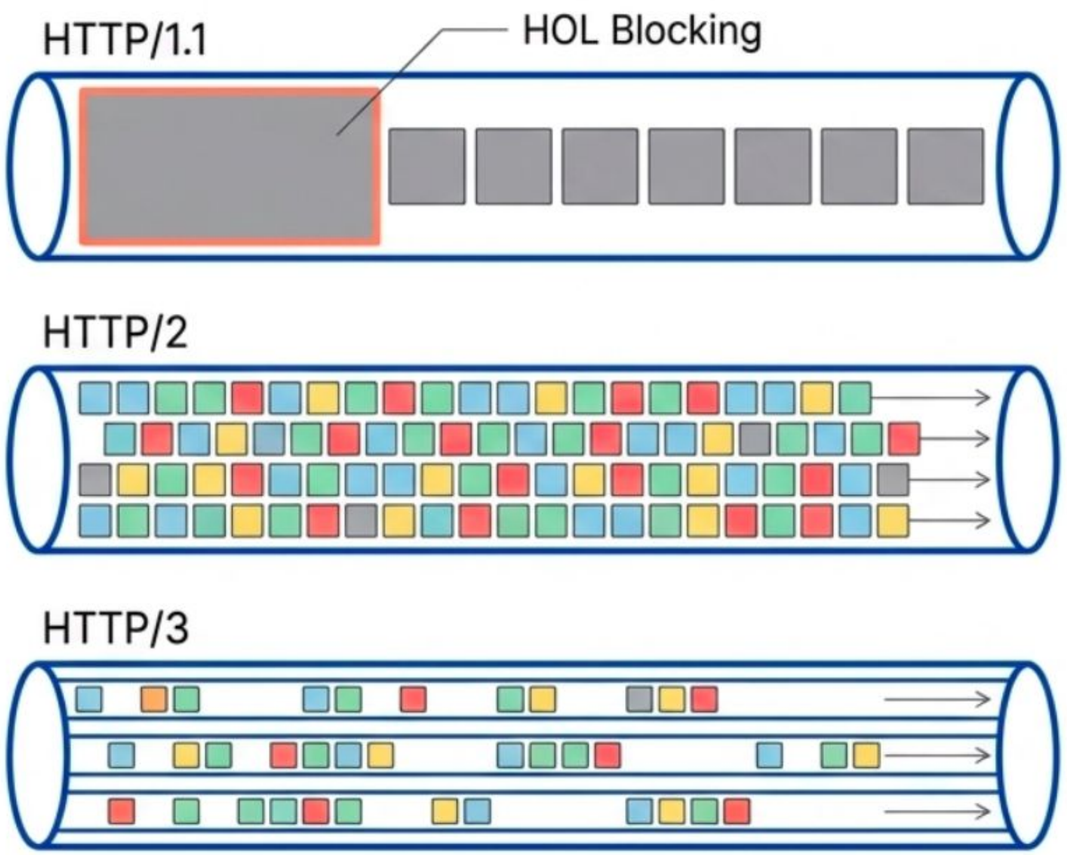
Conexões persistentes
RFC 2068

HTTP/2

- **Multiplexação**
  - **Múltiplas requisições/respostas ao mesmo tempo, eliminando o bloqueio *‘head-of-line’;***
  - **Ex: Diversas cabines de pedágio;**



HTTP/3



HTTP/2

Quebra as mensagens em quadros binários. Permite multiplexação total sobre uma única conexão TCP, intercalando requisições e respostas. Inclui compressão de cabeçalhos e push do servidor.

HTTP/3 (QUIC)

Mudança de paradigma na camada de transporte. Abandona o TCP em favor do protocolo QUIC (operando sobre UDP). Elimina o HOL blocking na camada de transporte e consolida os handshakes de rede e segurança para resiliência extrema a perda de pacotes.

Com base no que falamos até o momento: Qual é o principal problema do HTTP?

Segurança do HTTP

Tráfego em Plaintext

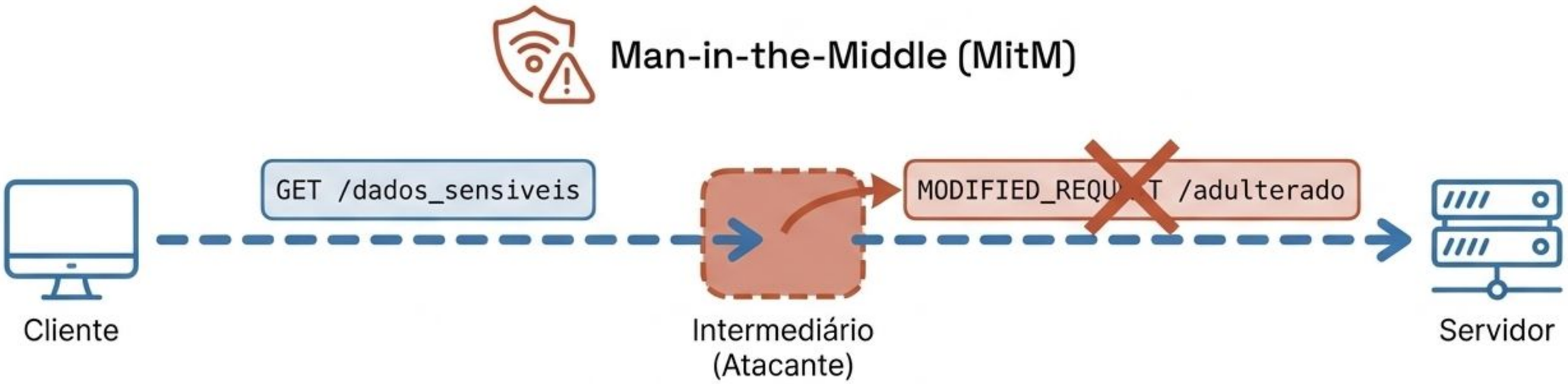
- Ausência de ofuscação nativa no protocolo HTTP.

Man-in-the-Middle (MitM)

- Vulnerabilidade absoluta à interceptação e adulteração em roteadores intermediários.

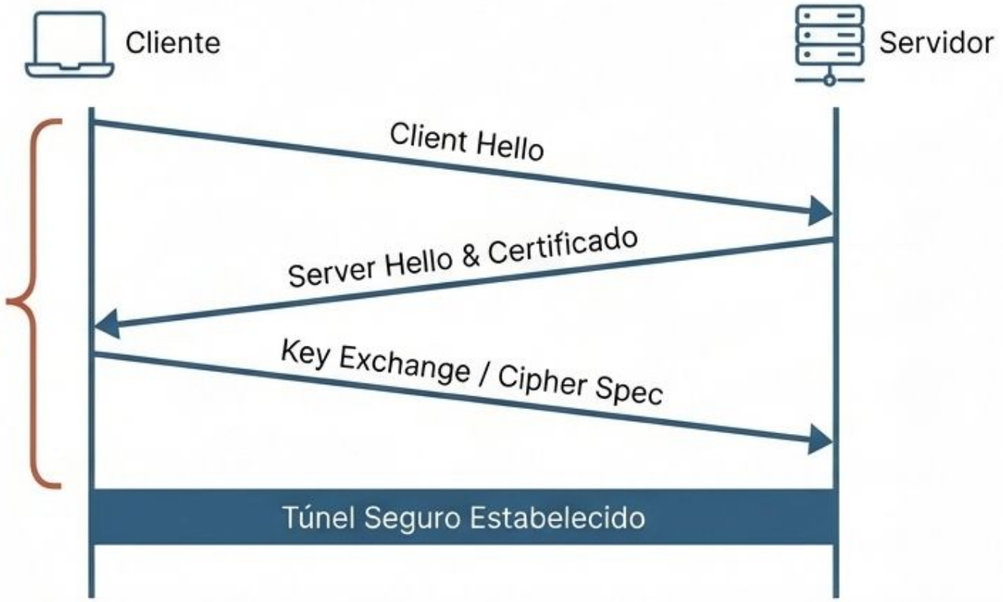
Falta de Autenticidade

- Impossibilidade de garantir que o servidor de destino é legítimo.

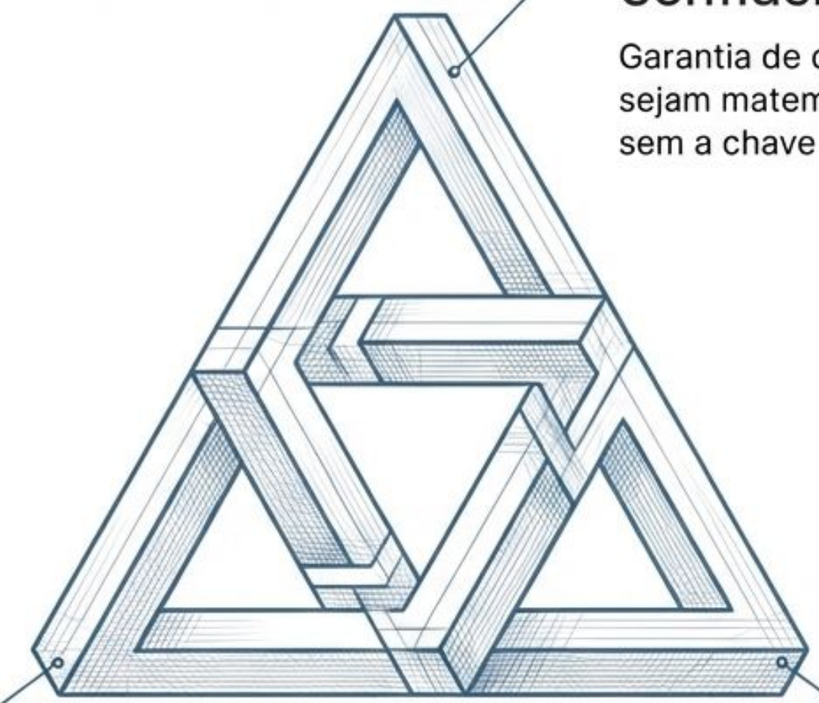


HTTPS

- Não é um protocolo novo, mas o HTTP operando sobre uma camada de segurança, o TLS (*Transport Layer Security*);
  - TLS handshake;
  - Identificação pelo certificado digital;
  - Se é válido, troca de informações criptografadas com base em uma chave secreta;



A Tríade CIA - 3 garantias do TLS



Confidencialidade

Garantia de que dados interceptados sejam matematicamente indecifráveis sem a chave correta.

Integridade

Detecção algorítmica de qualquer modificação durante o trânsito.

Autenticidade

Validação inquestionável da identidade das partes envolvidas.

Introdução à Criptografia

- **Garantindo a confidencialidade;**
  - **Primeira camada de proteção: caixa trancada com chave secreta compartilhada);**
  - **Criptografia simétrica - Chave para cifrar e decifrar (Eficiente);**
  - **Desafio na distribuição segura das chaves;**

Como transmitir a chave secreta de forma segura pela internet?

Criptografia simétrica vs assimétrica

Simétrica (Ex: AES)

Alta performance. Desafio: Distribuição segura da chave.

Assimétrica (Ex: RSA)

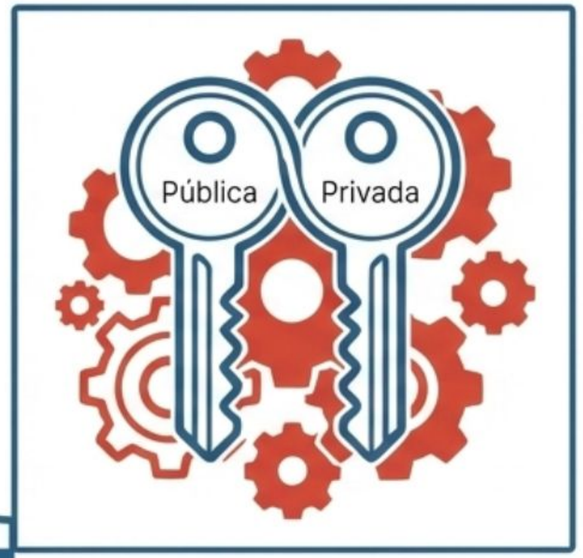
Par de chaves (Pública/Privada). Resolve distribuição, mas possui alto custo computacional.

O Modelo Híbrido (TLS)

Assimétrica para o Handshake e Simétrica para o túnel de dados.

Perfect Forward Secrecy (PFS)

Chaves efêmeras; protege o passado caso a chave mestre vaze no futuro.



Como sabemos que o conteúdo da requisição HTTP não foi alterada?

Funções hash

Funções Unidirecionais (SHA-256)

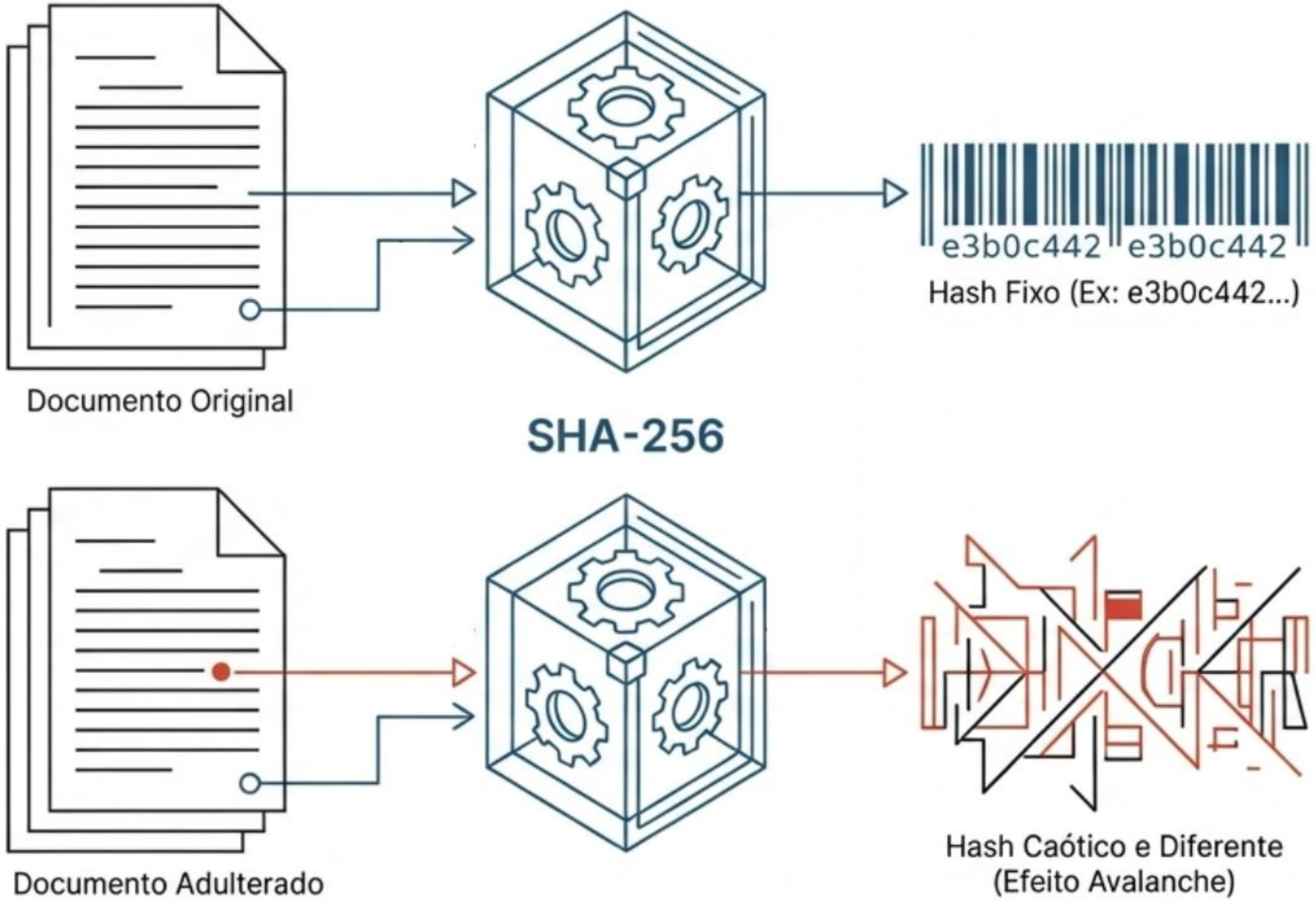
Geração de um resumo de tamanho fixo a partir de qualquer volume de dados.

Prevenção de Adulteração

O Efeito Avalanche: Qualquer alteração mínima no payload original altera drasticamente o hash.

Resistência a Colisões

A probabilidade de dois payloads diferentes gerarem o mesmo hash é inviável.



- *Página 83 do livro Redes de Computadores e a internet de Kurose e Ross;*

Assinaturas digitais

Assinaturas Digitais

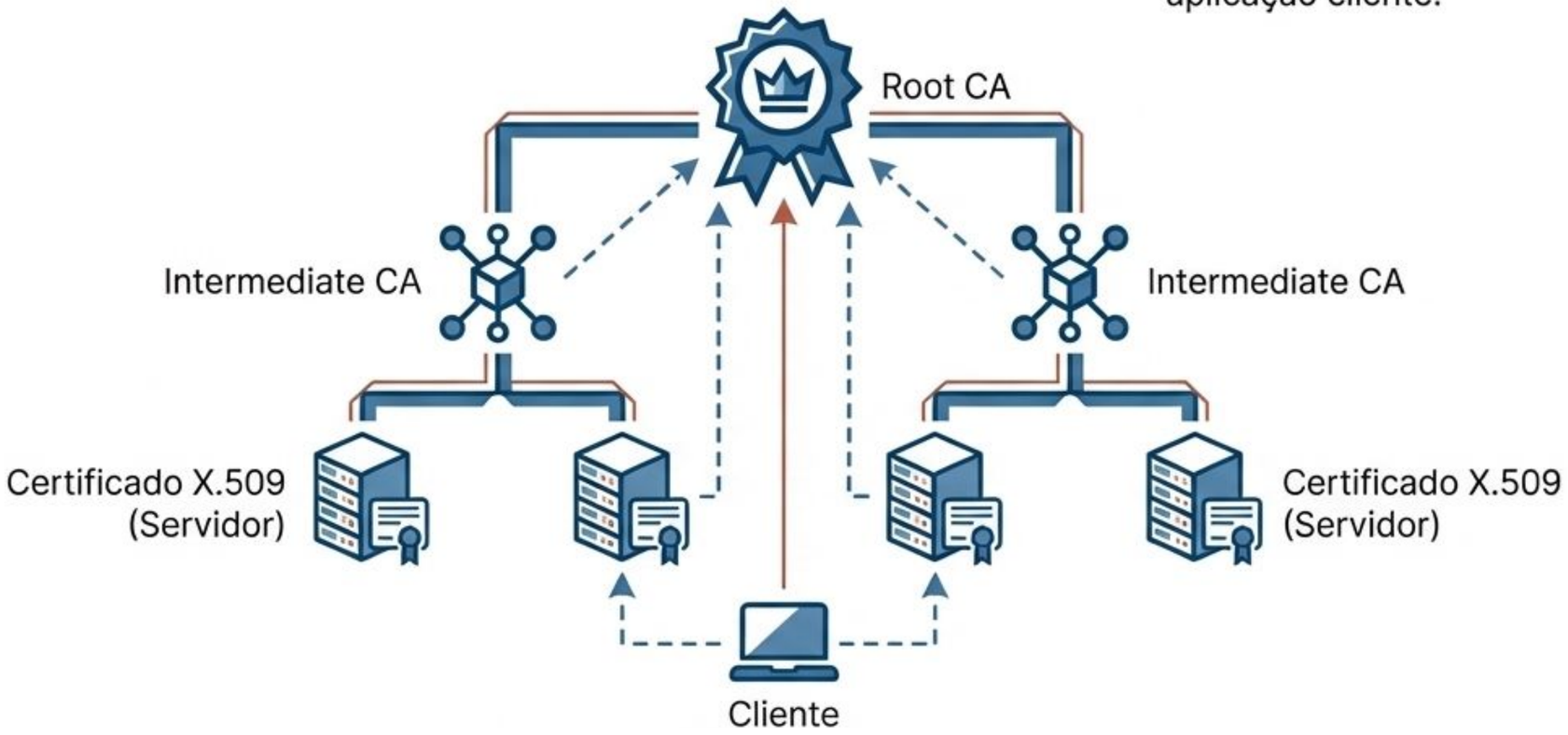
Hash cifrado com a chave privada garante Autenticidade e Não-Repúdio.

Certificados X.509

Vinculam matematicamente uma chave pública a uma identidade corporativa.

Infraestrutura de Chaves Públicas (PKI)

Autoridades Certificadores (CAs) formam a cadeia de confiança para a aplicação cliente.



Introdução à Chamada de Procedimento Remoto (RPC)

O Problema Distribuído

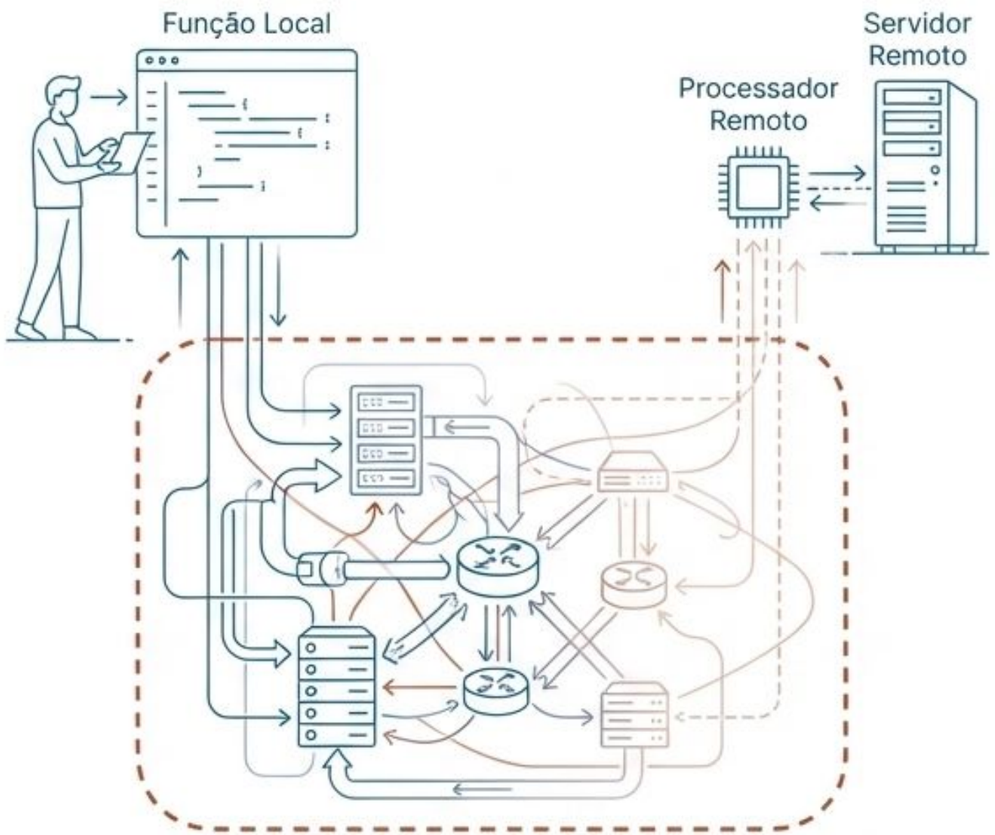
Sistemas escaláveis exigem comunicação complexa entre máquinas, lidando com soquetes e latência.

O Conceito RPC

Transparência de acesso: invocação de funções remotas como se fossem perfeitamente locais.

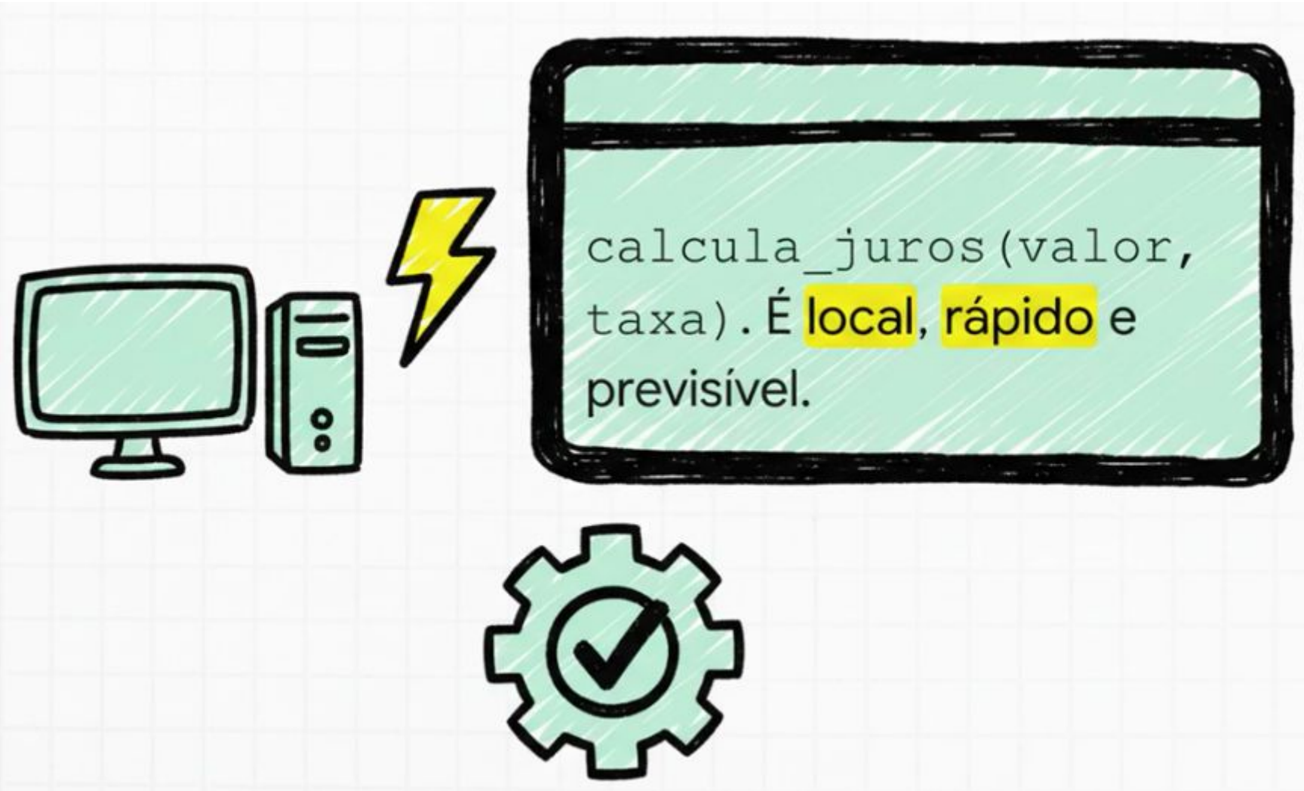
Abstração de Rede

Ocultamento do roteamento, empacotamento e falhas de transporte.



Exemplo de função local

- **Execução local, instantânea e previsível;**



E se esta função estivesse em um servidor remoto?

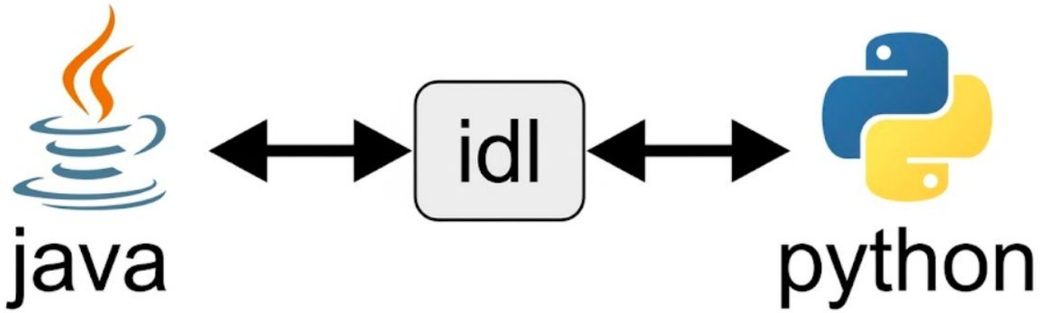
O Fluxo RPC

1. Chamada Local
Cliente chama o stub do cliente como uma função normal.
client stub
2. Marshalling
Stub do cliente empacota os parâmetros em uma mensagem.
3. Rede
A mensagem é enviada ao servidor.
Unmarshalling
Stub do servidor desempacota a mensagem.
5. Execução
Stub do servidor chama o procedimento real com os parâmetros.
6. Retorno
O resultado percorre o caminho inverso.

IDL (*Interface Definition Language)*

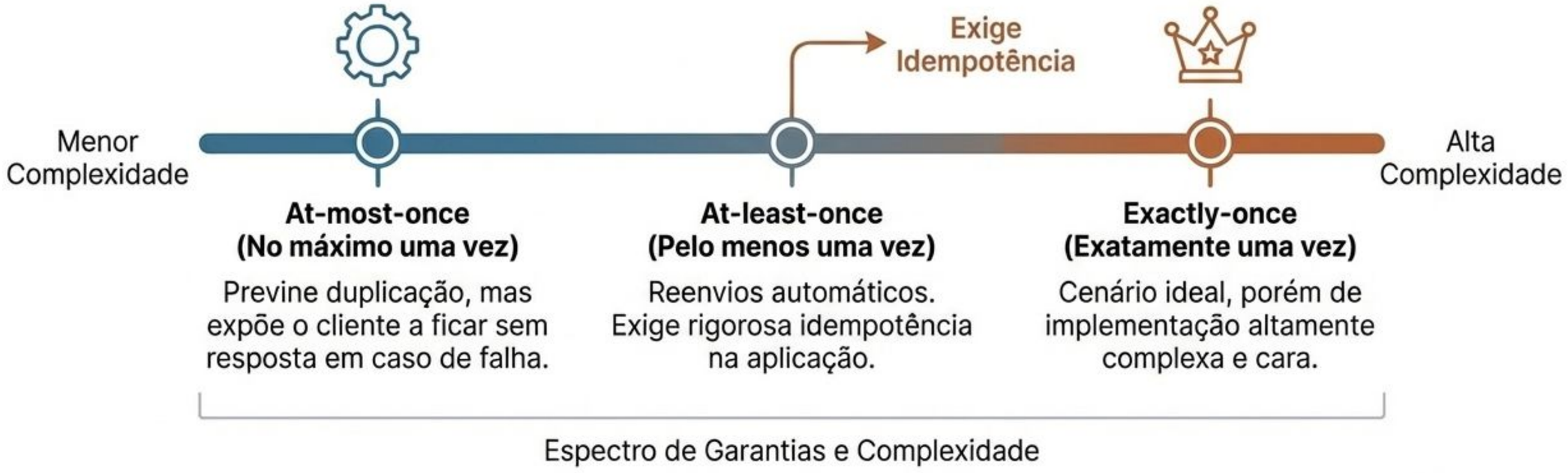
- **Os stubs seguem um contrato definido por uma IDL (funções e tipos de dados disponíveis);**

- **Linguagem de definição do contrato (métodos, tipos) entre cliente e servidor para interoperabilidade;**



Semânticas de falha em RPC

- **RPC esconde a rede, porém redes falham. Pacotes perdidos, quedas de servidor e timeouts;**



gRPC e Protocol Buffers

- Idéias fundamentais do RPC são de ~1980;

- Estão em alta para sistemas de alto desempenho (ex: gRPC);
- gRPC utiliza os conceitos clássicos e os moderniza;

- Troca de Formato de texto JSON para Binário compacto e rápido;

- Utiliza como base o HTTP/2, permitindo várias requisições em uma conexão;

- Criptografia por padrão;

HTTP vs RPC

Trade-off de Comunicação

- Legibilidade e ubiquidade (REST) vs. Eficiência e tipagem forte (gRPC).

Segurança como Fundamento

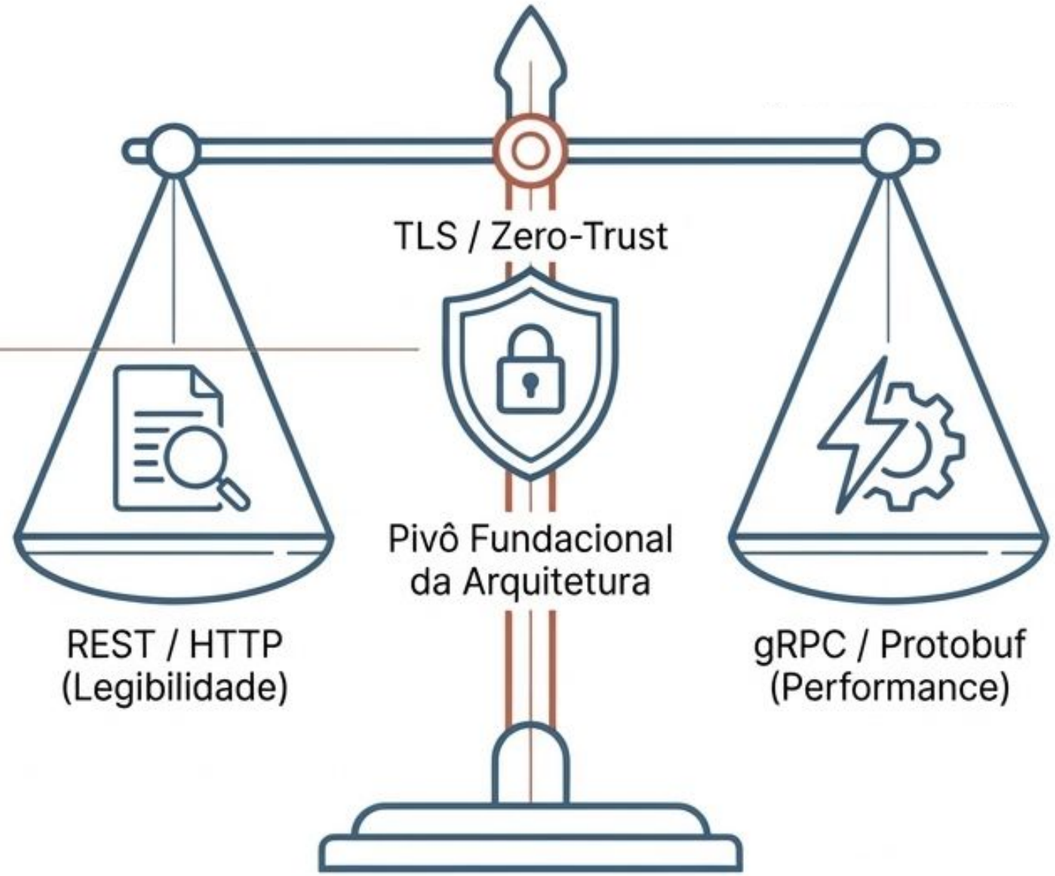
- Criptografia híbrida (TLS/PKI) é inegociável em arquiteturas Zero-Trust.

Tolerância a Falhas

- O design distribuído exige controle de estado (Idempotência) e consciência de rede.

Próximos Passos

- Avaliação pragmática de custos para escolha do protocolo ideal.



Exemplo para estudo

https://github.com/willianmarquesfreire/aula-redes

Referências

- KUROSE, James; ROSS, Keith. Redes de computadores e Internet. São Paulo: Person, 2006.

- TANENBAUM, Andrew S.; WETHERALL, David J. Computer Networks. 5. ed. Boston: Pearson, 2011.